

GDRock Platform Guide: WooCommerce

Step-by-step GDPR compliance for WooCommerce stores · 2026

WooCommerce runs on WordPress, which gives you full control — but also full responsibility. This guide covers every GDPR step specific to WooCommerce stores. Follow in order.

Step 1 · Publish Your Privacy Policy

- Go to WordPress admin → Pages → Add New
- Title: Privacy Policy · Slug: privacy-policy
- Paste the GDRock Privacy Policy template — fill {{STORE_NAME}}, {{DATE}}, {{PRIVACY_EMAIL}}
- Publish the page
- Go to Settings → Privacy → select your new page as the Privacy Policy page
- Add it to your footer menu: Appearance → Menus → add Privacy Policy page

Step 2 · Install the Cookie Banner

- Go to Appearance → Theme Editor → header.php (or use a child theme)
- Paste the GDRock Cookie Banner Script just before the closing tag
- Alternatively: use a plugin like Insert Headers and Footers to paste the script safely
- Save — test in an incognito browser window to confirm the banner appears
- Click Reject → reload → check DevTools Network tab to confirm no analytics fire
- Click Accept → reload → confirm Google Analytics or other scripts now load

Step 3 · Configure WooCommerce Privacy Settings

- Go to WooCommerce → Settings → Advanced → Account & Privacy
- Set Account erasure requests: enable customer data erasure on request
- Set Personal data retention: set order data to 7 years (statutory requirement)
- Enable: Send me a copy of my personal data (data portability)
- Add your Privacy Policy page URL to the checkout Privacy Policy field
- Enable: Allow customers to remove their account (right to erasure)

Step 4 · Sign Data Processing Agreements

- WooCommerce (Automattic) DPA: available at automattic.com/gdpr/
- WooPayments / Stripe DPA: accept in your Stripe dashboard under Settings → Compliance
- Hosting provider DPA: contact your host (SiteGround, Kinsta, etc.) for their DPA
- Mailchimp/Klaviyo DPA: sign in your email platform settings

- Google Analytics: accept Data Processing terms in GA4 settings → Data Collection

Step 5 · Handle Data Subject Requests

- WooCommerce has built-in tools: WooCommerce → Settings → Advanced → Account & Privacy
- For erasure requests: go to Tools → Erase Personal Data
- For data export requests: go to Tools → Export Personal Data
- You have 30 days to respond to each request — log all requests in a spreadsheet
- Inform sub-processors (Stripe, Mailchimp) to delete the customer data too

Step 6 · Secure Your WordPress Installation

- Keep WordPress, WooCommerce, and all plugins updated at all times
- Use a security plugin: Wordfence or Sucuri (free tiers available)
- Enable two-factor authentication for all admin accounts
- Use strong, unique passwords — store in a password manager
- Install an SSL certificate (HTTPS) — most hosts provide this free via Let's Encrypt
- Limit login attempts to prevent brute-force attacks
- Remove any unused plugins and themes — they are security risks

Step 7 · Test Your Compliance

- Open your store in incognito/private mode — confirm banner appears first
- Verify Reject stops all non-essential scripts
- Visit /privacy-policy — confirm it loads correctly and is complete
- Go through checkout — confirm privacy policy link appears
- Submit a test data export request via My Account and action it
- Run the GDRock free scanner at gdrock.com to check your score

Quick Reference: WooCommerce GDPR Checklist

■ Privacy policy page published and linked in footer	■ Done
■ Cookie banner with Accept/Reject installed	■ Done
■ WooCommerce Account & Privacy settings configured	■ Done
■ Data retention periods set in WooCommerce	■ Done
■ Automattic/WooCommerce DPA acknowledged	■ Done
■ Payment processor DPA signed	■ Done
■ Hosting provider DPA signed	■ Done

■ Email platform DPA signed	■ Done
■ Google Analytics DPA accepted	■ Done
■ WordPress and all plugins kept up to date	■ Done
■ 2FA enabled on all admin accounts	■ Done
■ HTTPS enabled on entire store	■ Done
■ Process for data subject requests documented and tested	■ Done